

# Enterprise Artificial Intelligence Acceptable Use Policy

**Version:** 1.0

**Effective Date:** June 5, 2026

**Document Owner:** Kyle Joseph Picard, GRC Analyst

## 1. Purpose

This policy establishes clear and secure guidelines for the use of Large Language Models (LLMs) and other Generative AI tools within the corporate environment. This framework allows the organization to safely leverage AI capabilities to maintain operational efficiency while ensuring all personnel follow strict protocols to protect confidential data, safeguard intellectual property, and maintain regulatory compliance.

## 2. Scope

This policy applies to all employees, contractors, consultants, temporary staff, and third-party vendors who access the corporate network, handle corporate data, or utilize organizational resources to access AI tools. This policy governs the use of AI on both corporate-issued devices and personal devices utilized for corporate business under a BYOD (Bring Your Own Device) model.

## 3. Regulatory Alignment

The controls within this policy are designed to ensure strict adherence to the HIPAA Security Rule regarding the transmission and processing of electronic Protected Health Information (ePHI). Furthermore, the data handling classifications outlined herein align directly with the risk management principles established by the NIST Artificial Intelligence Risk Management Framework (AI RMF) and NIST SP 800-53 privacy controls.

## 4. AI Tool Classification

To prevent unauthorized data exposure, the organization categorizes AI tools into two distinct groups:

### 4.1 Approved Enterprise AI Tools

Approved tools are limited exclusively to enterprise-licensed AI platforms that have undergone a formal vendor risk assessment by the Information Security Team. These tools operate under explicit contracts guaranteeing that organizational input data is siloed and will not be used to train external or public models.

## 4.2 Prohibited Public AI Tools

The use of public, consumer-grade Generative AI models (e.g., public ChatGPT, public Gemini, Claude) for any corporate business process involving non-public data is strictly prohibited. These public platforms frequently utilize user prompts for continuous model training, representing a critical risk of data leakage.

## 5. Data Classification and AI Usage Rules

The type of data being processed dictates which AI tools, if any, may be utilized.

- **Public Data:** Information that has been formally approved for public release (e.g., published marketing materials, public website copy). This data may be used in both Approved Enterprise tools and, with manager discretion, Prohibited Public tools.
- **Internal/Proprietary Data:** Internal communications, unreleased source code, financial summaries, and internal meeting notes. This data may only be entered into Approved Enterprise AI Tools. Inputting this data into public AI models is strictly prohibited.
- **Confidential Data & ePHI/PII:** Under NO circumstances shall Protected Health Information (PHI), Personally Identifiable Information (PII), client intake records, or biometric telemetry be entered into ANY Generative AI tool, including Approved Enterprise tools, unless a specific, written exception has been granted by the Chief Information Security Officer (CISO) following a formal risk assessment.

## 6. Employee Responsibilities

- **Output Verification:** AI tools are prone to hallucinations. Employees are strictly responsible for manually verifying and fact-checking all AI-generated outputs for accuracy, bias, and compliance before utilizing the information in any internal or external business process.
- **Code Review:** Any software code generated or assisted by AI must be treated as untrusted and must undergo rigorous peer review and automated vulnerability scanning before being committed to a production environment.
- **Ethical Use:** AI tools shall not be used to generate malicious code, attempt to bypass network security controls, create deepfakes, or generate content that violates the organization's Code of Conduct or Harassment policies.

## 7. Incident Reporting

Data spillage into public AI models represents a critical security incident. If an employee suspects that Internal, Confidential, or ePHI data has been accidentally exposed to an unauthorized AI tool, they must immediately cease use of the tool and report the incident to the Information Security Team via the established incident ticketing system or the emergency hotline.

## 8. Enforcement

Compliance with this Acceptable Use Policy is mandatory. Violations of these guidelines will result in an immediate investigation and may lead to the suspension of network access privileges, mandatory compliance retraining, and further disciplinary action, up to and including termination of employment or contract.

### Approval Signatures:

- GRC Analyst: \_\_\_\_\_
- CISO: \_\_\_\_\_